

Third-Party Compliance Evaluations

CompTIA SecAI+: AI Security Certification Complete Exam Prep 2026 | Section 26: Compliance Frameworks and Standards

1. The Extended Compliance Perimeter

An organization's AI compliance posture is only as strong as its weakest vendor. Every AI tool acquired externally, every API integration, and every foundation model accessed through a cloud provider creates a link in a compliance chain that extends far beyond organizational boundaries. Third-party compliance evaluation is the systematic process of assessing whether vendors, partners, and suppliers meet the AI governance requirements your organization must satisfy — and ensuring those requirements flow down into contracts. This is not an optional governance add-on; it is a formal requirement under ISO/IEC 42001:2023 Annex A.2.4 and a de facto expectation under the EU AI Act for deployers of third-party high-risk AI systems.

The critical insight is that compliance responsibility cannot be fully transferred to a vendor. Deploying a non-compliant third-party AI system makes your organization non-compliant, regardless of what the vendor represents in a questionnaire. Contractual provisions must operationalize the compliance requirements the vendor is expected to satisfy — and those provisions must be verifiable, not merely declaratory.

2. The AI Supply Chain: Layers of Risk

AI supply chains are significantly more complex than traditional software supply chains. A single enterprise AI system may depend on multiple distinct providers, each introducing specific compliance risks.

Supply Chain Layer	Examples	Key Compliance Risks
Foundation Model Provider	OpenAI, Anthropic, Google, Meta open-source	Training data licensing, data use for model improvement, transparency
Fine-Tuning Service	Specialist ML vendors, cloud ML platforms	Customer data used for training, data isolation between tenants
Training Infrastructure	AWS, Azure, GCP cloud compute	Data residency, government access rights (CLOUD Act), jurisdiction risk
Training Datasets	Licensed data brokers, web-scraped corpora	Unlicensed personal data, GDPR compliance of dataset sources
Inference Infrastructure	Cloud API endpoints, SaaS AI platforms	Data in prompts, logging of inference inputs and outputs
RAG / Vector Database Services	Pinecone, Weaviate, managed vector DBs	Data residency of embedded documents, access control gaps
AI Monitoring Platforms	MLflow, Arize, Fiddler, WhyLabs	Access to model outputs, exposure of sensitive inferences
API Integrations	Third-party APIs connecting AI to enterprise systems	Scope of data transmitted, terms-of-service changes post-acquisition

A single weak link in this stack propagates risk across the full deployment. A foundation model trained on unlicensed personal data, a dataset provider with poor security, or an API vendor that modifies data use terms post-acquisition can each create compliance failures that the deploying organization must answer for.

3. Real-World Context: API Acquisition and Data Use Change

Real-World Incident — Financial Services API Breach via Acquired Vendor (2023, Composite): A financial services firm used a third-party OCR and document extraction API. When the vendor was acquired, the new parent company modified the API terms of service to permit using customer document content for model improvement — retroactively. The firm's legal team missed the update. A subsequent breach at the parent company exposed client KYC documents containing personal and financial data. The firm faced GDPR Article 33 obligations, regulatory inquiry, and reputational damage. The root cause: the initial vendor compliance evaluation had no provisions for notification of terms-of-service changes and no ongoing monitoring of vendor acquisitions. This illustrates that compliance assessment at procurement is insufficient without continuous monitoring and contractual change notification clauses.

This pattern is not isolated. API vendor acquisitions routinely change data use terms, security postures, and compliance commitments. Contracts must require advance notice of material changes and include termination rights if those changes affect compliance posture.

4. Procurement Questionnaire: What to Ask AI Vendors

Effective third-party evaluation begins at the procurement stage with questions that surface compliance-relevant information before contract execution. Critically, answers must be contractually binding — a questionnaire response not incorporated into the contract provides no enforceable protection.

- **Data Governance** — Where is training data sourced, and is it licensed for AI training use? Does the vendor process customer data for model improvement, and if so, is there a contractually guaranteed opt-out mechanism?
- **Data Residency** — Where are AI processing and storage performed? Do those locations satisfy your data residency requirements under EU GDPR, China PIPL, or India DPDPA?
- **Security Controls** — What adversarial robustness testing has been performed on the AI system? What is the vendor's vulnerability management and incident response process specifically for AI components?
- **Compliance Certifications** — Does the vendor hold ISO/IEC 42001:2023 certification, and what is its scope? For EU-facing deployments, what is the vendor's EU AI Act compliance posture for high-risk AI systems?
- **Subprocessors (Fourth-Party Risk)** — What additional AI providers does the vendor depend on? How are subprocessor compliance requirements governed? Who bears liability for subprocessor failures?
- **Change Management** — What advance notification (typically 30-90 days) does the vendor provide for material changes to AI model versions, training data practices, subprocessors, or terms of service?

- **Right to Audit** — Does the contract permit your organization or a designated auditor to review AI technical documentation, security assessment reports, and data processing records?

5. Contractual AI Provisions: Beyond the Standard MSA

Standard Master Service Agreements are not designed for AI procurement. Enterprise AI contracts should include several AI-specific provisions that general MSA templates omit.

- **AI-Specific Data Processing Agreements (DPAs)** — Must specify: prohibition on using customer data for model training without explicit consent; data deletion obligations on contract termination; breach notification timelines aligned with GDPR's 72-hour requirement; and technical security specifications for AI processing infrastructure.
- **AI Performance SLAs** — Should address model accuracy maintenance over time, drift monitoring commitments, and incident response obligations for AI system failures or anomalous behavioral changes.
- **Change Notification Provisions** — Require 30-90 days advance notice for material changes to AI model versions, training data practices, terms of service, or subprocessors. Include a right to exit without penalty if changes affect compliance posture.
- **Audit Rights** — Contractual right to inspect AI technical documentation, penetration test results, and security certification reports. Define what inspection means: direct access, summary reports, or third-party audit attestation.
- **Liability and Indemnification for AI Harms** — Clear allocation of liability for AI-generated outputs causing third-party harm, regulatory fines, or breach notification costs. Vendor AI capability representations must be warranted, not merely stated.

Contract Principle: Every compliance commitment extracted via a procurement questionnaire must be incorporated into a binding contractual obligation. Questionnaire representations not contractually enforceable provide no meaningful protection. Regulators and courts evaluate what the contract required — not what the vendor said in a sales process.

6. EU AI Act: Dual Compliance Obligations for Third-Party High-Risk AI

The EU AI Act does not allow deployers to fully outsource compliance responsibility to AI providers. For high-risk AI systems, both the provider and the deployer carry specific, non-transferable obligations.

Party	Key EU AI Act Obligations	Cannot Be Transferred
AI Provider (Vendor)	Conformity assessment; CE marking; technical documentation; EU database registration; post-market monitoring	Provider obligations for systems they develop and place on the market
AI Deployer (Your Org)	Fundamental rights impact assessment (certain contexts); ensure system used as intended; maintain operational logs; implement human oversight	Deployer regulatory obligations — retained regardless of vendor contract terms
Both Parties	Data governance for personal data processed by the AI; incident reporting to	Neither party can contractually eliminate their own obligations

	national competent authority	under the Act
--	------------------------------	---------------

Practical implication: procurement agreements must explicitly allocate which party is responsible for which EU AI Act obligations. Assuming the vendor's CE marking eliminates the deployer's obligations is a compliance error. Deployers must conduct their own fundamental rights impact assessment regardless of the provider's conformity documentation.

7. Shared Responsibility Model for AI Vendor Deployments

A shared responsibility model helps allocate compliance obligations in cloud-based AI deployments. Understanding where each party's responsibility begins and ends is essential for both procurement negotiations and internal control design.

Domain	Cloud Infra Provider	AI Vendor	Deploying Org
Physical and infrastructure security	Full	None	None
AI model safety and content filtering	None	Full (managed models)	Configuring available controls
Data classification of AI inputs	None	None	Full
Access control to AI services	Platform IAM primitives	API key management	User and app access control
Human oversight of AI outputs	None	None	Full
Regulatory compliance (deployer obligations)	None	None (deployer-specific)	Full
AI incident reporting to regulators	None	Provider obligations	Deployer obligations

8. Ongoing Monitoring: Compliance Is Not Point-in-Time

Third-party AI compliance assessment at procurement captures a snapshot at a single moment. Both AI systems and the regulatory environment change — a vendor compliant at procurement may be non-compliant 18 months later.

- **Annual Reassessment** — Conduct periodic review of high-risk AI vendor compliance posture against current regulatory requirements. Reassess more frequently for critical AI vendors, especially as EU AI Act compliance deadlines phase in.
- **Production Behavioral Monitoring** — Monitor AI model performance to detect accuracy degradation or behavioral drift that may indicate undisclosed model updates. Material output shifts may signal model retraining without notification.
- **Security Advisory Subscriptions** — Subscribe to vendor CVE and security advisory notifications for AI components. AI frameworks such as PyTorch, TensorFlow, and Hugging Face libraries have active vulnerability disclosure programs.
- **Terms-of-Service Monitoring** — Assign responsibility for monitoring vendor terms-of-service changes. Consider vendor risk management tooling that tracks ToS changes automatically.

- Contract Renewal Reviews — Use renewal as a scheduled compliance checkpoint. Incorporate updated regulatory requirements, particularly evolving EU AI Act provisions, into renewed agreements.
- Acquisition and Material Event Triggers — Treat vendor acquisitions, leadership changes at critical AI vendors, and major security incidents as triggers for out-of-cycle reassessment.

9. ISO/IEC 42001:2023 and Vendor Due Diligence as Accountability

ISO/IEC 42001:2023 Annex A.2.4 requires organizations to conduct due diligence on AI suppliers and include AI governance requirements in supplier agreements. This is a management system control that auditors test during certification. Demonstrating compliance requires evidence: completed procurement questionnaires, contractual AI governance provisions, and records of periodic reassessment.

The accountability dimension is equally important. When an AI vendor causes harm — through training data practices, model behavior failures, or security incidents — the deploying organization shares accountability unless it can demonstrate that appropriate due diligence was exercised. 'We trusted the vendor's representations' is not a sufficient defense when contractual provisions and assessment records are absent. Annex A.2.4 operationalizes due diligence as a management system control precisely because thorough vendor oversight is both an ethical obligation and a regulatory risk mitigation.

10. AI Model Supply Chain Security

Traditional software supply chain security principles — dependency verification, integrity checking, provenance tracking — extend directly to AI model supply chains. Organizations using open-source foundation models from registries like Hugging Face face supply chain risks analogous to npm or PyPI dependency risks: a malicious actor could upload a model purporting to be a legitimate version with backdoor behaviors embedded during training.

- Verify model provenance — use only models from verified sources with documented training data provenance and organizational accountability.
- Check SHA-256 hashes of downloaded model weights against registry-published checksums to confirm the file has not been tampered with.
- Monitor for unexpected behavioral changes after model updates — shifts in output patterns may indicate model substitution.
- Apply model scanning tools such as Protect AI's ModelScan and Hugging Face's malware scanning to downloaded model files before deployment.
- Treat model registry dependencies as software dependencies — pin versions, audit before updating, review changelogs for behavioral changes.

Supply Chain Security Analogy — XZ Utils Backdoor (2024): The XZ Utils attack embedded malicious code in a widely used open-source compression library through a sustained social engineering campaign against its maintainer. The attacker gained contributor trust over many months before inserting the backdoor in a release. The same pattern transfers directly to AI model supply chains: a compromised foundation model could include trigger behaviors invisible in normal use but activated by specific prompt patterns. Section 21 of this course covers CI/CD and software supply chain security; AI model supply chain security is a parallel emerging discipline applying the same principles to model weight files.

Key Terms Glossary

Term	Definition
Third-Party Risk Management	The organizational process of identifying, assessing, and mitigating risks introduced by vendors, suppliers, and partners — extended to AI systems and AI supply chain components.
AI Supply Chain	The end-to-end set of providers, datasets, infrastructure, and tools contributing to an AI system — including foundation model providers, training data sources, cloud infrastructure, and API integrations.
Data Processing Agreement (DPA)	A contract required under GDPR between a data controller and processor specifying scope, purpose, and conditions of personal data processing. AI-specific DPAs extend this to cover AI training data use restrictions.
Right-to-Audit Clause	A contractual provision permitting the customer or its designated auditor to review vendor documentation, security reports, and compliance records — essential for verifying AI vendor representations.
EU AI Act Deployer	Under the EU AI Act, an organization that puts a third-party AI system into professional use. Deployers retain specific compliance obligations that cannot be transferred to the AI provider.
ISO/IEC 42001 Annex A.2.4	The management system control requiring organizations to conduct due diligence on AI suppliers and incorporate AI governance requirements into supplier agreements.
Fourth-Party Risk	Risk introduced by a vendor's own vendors — the subprocessors and infrastructure providers that your direct (third-party) vendor relies upon. Commonly overlooked in procurement assessments.
Model Supply Chain Security	Application of software supply chain security principles to AI models — including provenance verification, integrity hash checking, and behavioral monitoring for signs of tampering or backdoor injection.
Standard Contractual Clauses (SCCs)	EU Commission-approved contractual clauses authorizing cross-border transfers of personal data from the EU to non-adequate third countries — applicable when AI vendors process EU personal data outside the EU.
Change Notification Provision	A contractual clause requiring advance notice (typically 30-90 days) before material changes to AI model versions, training data practices, subprocessors, or terms of service.

Quick Revision Checklist

- Compliance responsibility cannot be fully transferred to an AI vendor — deploying organizations retain their own regulatory obligations under the EU AI Act and applicable data protection laws.
- AI supply chains are multi-layered: foundation model provider, training data, infrastructure, fine-tuning services, API integrations, and monitoring platforms each introduce distinct compliance risks.

- Procurement questionnaire answers must be contractually incorporated — unenforceable representations provide no compliance protection.
- AI-specific DPA provisions: data use restrictions, deletion on termination, 72-hour breach notification, right-to-audit, advance change notification.
- EU AI Act creates dual obligations: AI providers and deployers of high-risk AI each carry non-transferable compliance responsibilities.
- Shared responsibility in cloud AI: cloud provider covers infrastructure; AI vendor covers model-level controls; deployer retains data classification, access control, human oversight, and regulatory compliance obligations.
- ISO/IEC 42001 Annex A.2.4 requires documented vendor due diligence — 'we trusted the vendor' is not a defense before regulators.
- Ongoing monitoring: annual reassessment, production behavioral monitoring, terms-of-service tracking, and acquisition event triggers for out-of-cycle review.
- Fourth-party risk (vendor's vendors) must be included in the compliance assessment scope.
- Open-source AI model supply chain security: verify SHA-256 hashes, scan model files, pin versions, monitor for behavioral drift after updates.

10 Exam-Based MCQs — Third-Party AI Compliance

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. *Scenario:* A financial services organization uses a third-party AI document processing API governed by a contract executed three years ago. The API vendor has been acquired by a larger technology company. Reviewing the acquiring company's updated terms of service, the security team notices the new terms permit using customer-submitted document content for AI model training, which would include client KYC documents containing personal and financial data. Which action should be the FIRST priority when the security team discovers that a third-party AI vendor has been acquired and the acquiring company has modified the API data use terms to permit training on customer data?

- A) Immediately terminate the vendor contract without legal review.
- B) Review the current contract for change notification and data use restriction provisions.
- C) Notify data subjects under GDPR Article 33 as a precaution.
- D) Conduct a new procurement questionnaire with the acquiring company.

Answer: B **Explanation:** B is correct because the immediate priority is establishing the legal and contractual position — does the contract prohibit this data use, was proper notice given, and what remedies are available? Only after understanding the contractual situation can appropriate next steps be taken. A is wrong because termination without legal review may trigger penalties and is premature before understanding the contract's provisions. C is wrong because GDPR Article 33 notification applies to personal data breaches, not to vendor terms-of-service changes — unless unauthorized processing constituting a breach has occurred, which has not been established. D is wrong because a new questionnaire does not address the immediate contractual issue with the existing relationship.

Q2. Scenario: A European retail bank is procuring a high-risk AI credit scoring system from a fintech vendor. The bank's legal team wants to ensure the vendor contract addresses the bank's EU AI Act obligations as an AI deployer. The compliance team is reviewing the procurement questionnaire. The organization's AI governance team is preparing an AI procurement questionnaire for a high-risk AI credit decisioning vendor. Which element is MOST critical to address the EU AI Act deployer obligations that cannot be transferred to the vendor?

- A) The vendor's ISO/IEC 42001 certification scope and certificate number.
- B) Documentation of how the vendor will conduct the fundamental rights impact assessment on the deploying organization's behalf.
- C) The vendor's AI system technical documentation package for regulatory inspection by the deploying organization.
- D) Contractual language allocating all EU AI Act compliance obligations to the vendor.

Answer: C Explanation: C is correct because the deploying organization has an EU AI Act obligation to ensure the AI system's technical documentation is available for regulatory inspection — obtaining this documentation from the vendor via contract is how deployers satisfy this specific obligation. A is wrong because ISO/IEC 42001 certification is valuable but addresses management system compliance rather than the specific EU AI Act deployer obligation to have technical documentation accessible. B is wrong because the fundamental rights impact assessment is the deployer's own non-transferable obligation — the vendor cannot perform it on the deployer's behalf. D is wrong because EU AI Act deployer obligations cannot be contractually assigned to the vendor; the Act creates non-transferable regulatory duties.

Q3. Scenario: A cybersecurity consulting firm is performing a third-party AI governance assessment for a healthcare organization that has a mature internal AI governance program — documented impact assessments and bias testing for internally developed AI. The assessment is now examining third-party AI tools, including an AI-powered clinical documentation assistant and an AI scheduling system. Which finding would a red team assessment of an organization's third-party AI procurement practices MOST likely identify as the highest-priority gap?

- A) The organization does not require vendors to hold ISO/IEC 42001 certification.
- B) Vendor AI systems are held to a lower compliance standard than internally developed AI, with gaps accepted on the basis of vendor representations alone.
- C) The procurement questionnaire does not ask for the vendor's AI model architecture details.
- D) The organization has not established AI performance SLA benchmarks for vendor systems.

Answer: B Explanation: B is correct because the highest-priority finding in third-party AI assessments is consistently that vendor AI systems receive compliance credit that internally developed AI would not receive, with gaps filled by trusting vendor representations rather than enforcing contractual provisions. This creates both regulatory exposure and exploitable coverage gaps. A is wrong because ISO/IEC 42001 certification is desirable but not mandatory — its absence is a gap but not the highest-priority finding when core contractual protections are also missing. C is wrong because AI model architecture details are technically useful but are not the primary compliance control gap. D is wrong because performance SLAs address service quality, not the fundamental compliance gap of dual standards.

Q4. ISO/IEC 42001:2023 Annex A.2.4 requires organizations to conduct due diligence on AI suppliers and include AI governance requirements in supplier agreements. What is the PRIMARY purpose of this control?

- A) To reduce procurement costs by standardizing vendor evaluation processes.
- B) To ensure the organization can demonstrate responsible AI governance even when AI capabilities are sourced externally.
- C) To satisfy ISO 27001 information security requirements for vendor management.
- D) To comply with EU AI Act provider requirements for AI systems the organization deploys.

Answer: B **Explanation:** B is correct because the purpose of Annex A.2.4 is to extend the organization's AI management system controls to its supply chain — ensuring responsible AI governance is maintained even when AI capabilities are externally sourced. Organizations with robust internal AI governance but superficial vendor oversight have a gap in their accountability posture that Annex A.2.4 addresses. A is wrong because cost reduction is not the purpose — due diligence typically adds procurement overhead. C is wrong because while ISO 27001 Annex A.15 covers supplier relationships, ISO 42001 Annex A.2.4 is specific to AI governance. D is wrong because EU AI Act provider requirements apply to organizations that develop and place AI systems on the market, not to organizations deploying third-party AI.

Q5. An organization purchases a managed AI inference service. Six months later, a security audit finds the cloud provider uses the organization's prompt data to improve the foundation model. Which contractual provision would BEST have prevented this?

- A) A right-to-audit clause permitting inspection of the cloud provider's security controls.
- B) A data use restriction clause prohibiting use of customer prompt data for model training without explicit consent.
- C) A performance SLA specifying AI model accuracy maintenance thresholds.
- D) A breach notification clause requiring 72-hour notification of security incidents.

Answer: B **Explanation:** B is correct because the specific issue — customer data used for model training without agreement — is directly addressed by a contractual data use restriction. This provision would prohibit the practice and create an enforceable remedy. A is wrong because audit rights permit inspection of security controls but do not prohibit the data use practice. C is wrong because accuracy SLAs address model performance, not data use. D is wrong because breach notification applies to security incidents, not to data use practices permitted under the contract terms. This question illustrates why AI-specific DPA provisions are essential beyond standard MSA terms.

Q6. Which of the following BEST describes 'fourth-party risk' in AI procurement?

- A) Risk from a vendor's merger with a fourth-tier competitor.
- B) Risk introduced by an AI vendor's own subprocessors and infrastructure providers.
- C) Risk from deploying four or more AI systems from the same vendor.
- D) Risk arising from the fourth phase of the AI development lifecycle.

Answer: B **Explanation:** B is correct because fourth-party risk refers to risks introduced by a vendor's own vendors — the subprocessors, infrastructure providers, and platform dependencies that your direct

(third-party) vendor relies upon. In AI contexts this commonly includes the foundation model provider a vendor's AI is built on or the cloud infrastructure the vendor uses for inference. A is wrong because vendor mergers are a third-party governance trigger but not the definition of fourth-party risk. C is wrong because the number of systems from a single vendor describes concentration risk, not fourth-party risk. D is wrong because this is a supply chain risk concept, not a development lifecycle stage.

Q7. Which of the following represents a valid analogy between software supply chain security and AI model supply chain security?

- A) Software dependency version pinning is analogous to AI model version pinning to prevent unauthorized model substitution.
- B) Software code review is analogous to reading AI model weights directly to detect embedded malicious logic.
- C) Standard antivirus scanning is sufficient for detecting malicious content embedded in AI model weight files.
- D) Software patch management is analogous to retraining AI models after each security vulnerability is identified.

Answer: A **Explanation:** A is correct because pinning software dependency versions to prevent unauthorized updates maps directly to pinning AI model versions — both prevent an attacker from substituting a malicious version for a legitimate one through an update mechanism, providing integrity guarantees about what is actually running in production. B is wrong because AI model weights are numerical parameters that cannot be meaningfully reviewed for malicious logic the way source code can be reviewed. C is wrong because traditional antivirus tools use signatures designed for executable code, not AI model weight formats such as safetensors or GGUF; dedicated tools like ModelScan are required. D is wrong because retraining models changes behavior unpredictably and is not a security patch mechanism analogous to software patching.

Q8. A vendor proposes removing the right-to-audit clause and offering annual third-party audit reports instead. What is the MOST significant compliance concern with this arrangement?

- A) Third-party audit reports are always less comprehensive than direct organization audits.
- B) Annual reports may not provide timely visibility into compliance changes, and the organization cannot control what the third-party auditor examines.
- C) Third-party audit firms charge higher fees than internal audit teams.
- D) ISO/IEC 42001 explicitly requires direct audit access and does not accept third-party audit reports.

Answer: B **Explanation:** B is correct because the key risks with third-party reports in lieu of direct audit rights are timeliness and scope control. Annual reports are retrospective and may not reveal material changes occurring between reporting periods. More critically, the organization cannot control what the third-party auditor examines — the vendor controls the engagement scope. A is wrong because third-party audit reports can be comprehensive when the auditor's scope is well-defined; the issue is scope control, not inherent report quality. C is wrong because audit cost is not the relevant compliance concern. D is wrong because ISO/IEC 42001 does not mandate the specific form of audit access — evidence of due

diligence can take multiple forms.

Q9. Which of the following AI vendor events should trigger an out-of-cycle compliance reassessment, in addition to the scheduled annual review?

- A) The vendor releases a minor patch update to their AI model (e.g., v2.1.0 to v2.1.1).
- B) The vendor is acquired by a larger technology company.
- C) The vendor adds a new AI feature the organization does not use.
- D) The vendor's Chief Executive Officer is replaced through routine succession.

Answer: B **Explanation:** B is correct because vendor acquisitions are high-impact events that can change data use terms, privacy policies, security postures, subprocessor relationships, and the contractual counterparty — all of which materially affect the compliance relationship. The real-world scenario in this lecture illustrates exactly this risk. A is wrong because minor patch updates typically do not change data use terms or compliance posture, though significant behavioral changes should be monitored separately. C is wrong because unused features do not change the compliance posture for the organization's existing use case. D is wrong because routine executive succession without organizational change does not typically affect compliance controls.

Q10. A company downloads an open-source large language model from Hugging Face to use as the foundation for its internal AI assistant. Which supply chain security control is MOST effective for detecting if the model weights have been tampered with before deployment?

- A) Running the model through a traditional antivirus scanner.
- B) Reviewing the model's README file on the model registry page.
- C) Verifying the SHA-256 hash of the downloaded model files against the registry-published checksum.
- D) Monitoring the model's output quality in production for one week after deployment.

Answer: C **Explanation:** C is correct because cryptographic hash verification detects any modification of the model file — a tampered model produces a different SHA-256 hash than the registry-published value, providing a reliable pre-deployment integrity check. This is the direct equivalent of package integrity verification in software supply chain security. A is wrong because traditional antivirus tools use signatures designed for executable code formats, not AI model weight formats such as safetensors or GGUF files. B is wrong because README files are text documents an attacker can also modify — they provide no cryptographic integrity assurance. D is wrong because production output monitoring detects anomalous behavior after deployment; by that point the organization has already deployed and relied upon a potentially compromised model.